

LEARNING RESOURCE GUIDE

ISC2 CCSP: Certified Cloud Security Professional (Aug 2026) | Professional Participant Workbook

Introduction to Domain 6: Legal, Risk and Compliance

1. Learning Objectives

- By the end of this lecture, you will be able to explain the six major topic areas covered in Domain 6 and state the exam weighting for the domain.
- By the end of this lecture, you will be able to describe how legal, contractual, and regulatory obligations interact within a cloud security program.
- By the end of this lecture, you will be able to identify the types of questions Domain 6 tests and the reasoning approach the exam rewards.
- By the end of this lecture, you will be able to connect Domain 6 topics to concepts from earlier domains, demonstrating how legal compliance sits on top of technical security controls.
- By the end of this lecture, you will be able to outline the integrated nature of legal requirements, privacy regulation, audit processes, risk management, and vendor management in a cloud context.

2. Introduction

Imagine you are the cloud security lead at a multinational financial services firm. Your organization has spent two years hardening its cloud environment: encryption at rest and in transit, identity and access management controls, continuous monitoring, and a mature incident response process. Then your legal team informs you that a regulatory examination has uncovered that your data residency configurations conflict with a privacy directive in one of your operating jurisdictions, and that your provider's audit reports do not cover the specific infrastructure tier your regulated workloads run on. The technical controls are sound. The legal and compliance infrastructure around them is not. The regulatory finding carries a potential fine that dwarfs the cost of the entire security program.

This scenario is representative of the failure mode Domain 6 is designed to prevent. Security decisions do not live in isolation. They live inside legal systems, contractual obligations, regulatory frameworks, and organizational risk programs. Domain 6 builds the professional competence to understand those structures and apply them to real cloud deployments. It accounts for 13 percent of the CCSP exam, meaning roughly 13 to 20 questions, and those questions are weighted toward applied judgment rather than simple recall.

For practitioners working toward CCSP certification, Domain 6 is where the technical knowledge accumulated in earlier domains meets the organizational and legal context in which that knowledge must operate. A cloud security professional who understands only the technology is still incomplete. Domain 6 completes the picture.

3. Core Concepts Explained

Legal Requirements in the Cloud

Definition: Cloud computing is a global technology, but law is local. A single cloud deployment can simultaneously trigger obligations under the laws of multiple countries, each with its own rules about data access, residency, breach notification, and government access to stored data.

Business relevance: Understanding which legal frameworks apply to a given cloud deployment is a prerequisite for designing appropriate controls. Organizations that deploy globally without mapping their legal obligations first routinely discover conflicts during audits or incidents, when remediation is most costly.

Practitioner angle: A practitioner approach involves maintaining a legal register alongside the risk register: a documented map of operating jurisdictions, data categories, and applicable legal frameworks. New cloud services are assessed against this register before deployment.

Real-world example: A US-headquartered retailer expanding into the EU discovers that its customer analytics platform, which was designed to US standards, does not meet GDPR requirements for data subject rights, lawful basis of processing, or cross-border data transfer restrictions.

Risk if neglected: Failing to map legal requirements before deployment results in remediation costs, regulatory fines, and reputational damage that technical controls alone cannot prevent.

eDiscovery and Digital Forensics

Definition: eDiscovery is the process of identifying, preserving, collecting, reviewing, and producing electronically stored information in response to legal proceedings or regulatory inquiries. Digital forensics is the investigation of incidents using digital evidence in a manner that meets evidentiary standards.

Business relevance: Cloud environments complicate both disciplines. Data may be distributed across jurisdictions, co-located with other customers' data on shared infrastructure, and inaccessible for raw acquisition without provider cooperation. Legal proceedings arrive on timelines that do not accommodate unpreparedness.

Practitioner angle: Practitioners build eDiscovery and forensic readiness into cloud architecture from the start: comprehensive audit logging, documented evidence handling procedures, and contractual provisions requiring provider cooperation with preservation and collection requests.

Real-world example: During a securities fraud investigation, a regulator issues a preservation notice requiring a financial services firm to retain all communications and transaction records for a two-year window. The firm discovers that its cloud messaging

platform's default retention is 90 days and that the provider's cooperation terms do not specify a response timeline.

Risk if neglected: eDiscovery and forensic capabilities cannot be built under pressure. The infrastructure must exist before it is needed.

Privacy: PII, PHI, and Data Classification

Definition: Personally Identifiable Information (PII) is any data that can identify an individual, alone or in combination with other data. Protected Health Information (PHI) is a legally defined subset regulated under HIPAA in the United States. The distinction between contractual and regulated private data determines who can enforce protection obligations and what consequences a failure carries.

Business relevance: Misclassifying data leads to applying the wrong control set. Regulated data in systems designed only for contractual obligations creates legal exposure that no subsequent technical remediation fully resolves.

Practitioner angle: Data discovery, classification, and mapping are foundational activities. Every cloud workload should be assessed for the categories of data it processes before controls are selected and before the system goes live.

Real-world example: A health technology company integrates its fitness tracking app with a hospital's electronic health record system. What was contractual PII becomes PHI regulated under HIPAA, triggering Business Associate Agreement requirements, audit logging mandates, and breach notification timelines that the existing architecture was not designed to meet.

Risk if neglected: Data classification errors are among the most common root causes of compliance failures in cloud environments.

Audit and Compliance

Definition: Audit in the cloud context encompasses understanding SOC report types (SOC 1, SOC 2, SOC 3, SOC 2+), the differences between internal and external audit processes, gap analysis against Information Security Management System frameworks, and how to scope an audit engagement for a cloud deployment.

Business relevance: Audit reports are the primary mechanism by which cloud customers verify provider security posture without direct access to provider infrastructure. Selecting the right report type for the right purpose, and understanding what each type does and does not cover, is a core professional competency.

Practitioner angle: Practitioners match audit report requirements to customer obligations during vendor selection, specify required audit report types in contracts, and schedule internal compliance reviews against the ISMS policy framework on a defined cadence.

Real-world example: An organization's SOC 2 Type II report covers the provider's shared infrastructure but excludes the customer-managed virtual machines and application layer. The customer's external auditor notes the gap and requests evidence that customer-layer controls are operating effectively, evidence the organization had not prepared.

Risk if neglected: Audit gaps that are discovered during external assessments are more costly to remediate than gaps caught through proactive internal review.

Enterprise Risk Management

Definition: Enterprise risk management in a cloud context involves assessing the organization's risk profile, selecting appropriate risk treatment strategies (avoidance, mitigation, transfer/sharing, acceptance), understanding cloud service provider risk programs, and managing data roles (controller, processor, steward) with their associated legal consequences.

Business relevance: Risk treatment decisions in cloud environments have direct contractual and legal implications. Transferring risk through cyber insurance requires understanding what the policy covers and how cloud-specific incidents are treated. Accepting risk requires documented executive acknowledgment. Avoidance may mean declining to deploy certain workloads in certain cloud models.

Practitioner angle: Practitioners align risk treatment decisions with legal obligations. A regulatory framework that mandates specific controls removes the option to accept risk in that area; risk treatment is constrained by compliance requirements.

Real-world example: A financial services organization assesses the risk of hosting customer payment data in a public cloud environment. Mitigation through encryption and access controls addresses technical risk. Transfer through cyber insurance addresses residual financial risk. But the regulatory framework for payment data may mandate specific storage and audit requirements that cannot be addressed through risk acceptance alone.

Risk if neglected: Treating compliance-driven controls as optional risk acceptance decisions is a fundamental misapplication of risk management in regulated environments.

Cloud Contracts and Vendor Management

Definition: Cloud contracts formalize the legal and commercial relationship between the customer organization and the cloud service provider. Key instruments include Service-Level Agreements (SLAs), Master Service Agreements (MSAs), Statements of Work (SOWs), right-to-audit provisions, cyber risk insurance requirements, and supply chain transparency obligations.

Business relevance: The contract is the primary mechanism for translating security requirements into enforceable obligations. A well-structured cloud contract provides the customer with defined remedies when the provider fails to meet agreed standards and preserves the customer's ability to verify provider compliance through audit rights.

Practitioner angle: Practitioners review proposed cloud contracts against a security requirements checklist that includes audit rights, data portability, incident notification timelines, breach liability allocation, termination and data return provisions, and supply chain transparency requirements.

Real-world example: An organization signs a cloud agreement that does not include a right-to-audit provision and does not specify an incident notification timeline. When the provider experiences a breach affecting the customer's data, the provider's notification arrives 72 hours after the customer's GDPR notification obligation to its own data subjects has already elapsed.

Risk if neglected: Cloud contracts that lack security-specific provisions transfer risk to the customer in ways that are difficult to remediate after signing.

4. Domain 6 Topic Areas at a Glance

Topic Area	Exam Weight Focus	Key Skill Tested	Primary Frameworks
Legal Requirements	High — scenario application	Identify applicable law for a given jurisdiction/data type	GDPR, HIPAA, CLOUD Act, ISO/IEC 27002, CSA CCM
eDiscovery & Forensics	Medium — standards recall + application	Apply correct standard to forensic evidence handling	ISO/IEC 27037, 27041, 27042, 27043, 27050; EDRM
Privacy (PII/PHI)	High — classification + consequences	Distinguish PII from PHI; contractual from regulated	GDPR, HIPAA, COPPA, FERPA, PIPEDA, DPDP Act
Audit & Compliance	Medium — report type selection	Choose correct SOC report for a given use case	SOC 1/2/3, ISO/IEC 27001, gap analysis
Enterprise Risk Management	High — treatment strategy selection	Select appropriate risk treatment given constraints	Standard risk treatment options; data role definitions
Cloud Contracts & Vendor Mgmt	Medium — contract term identification	Identify missing or inadequate contract provisions	SLA, MSA, SOW, SOX, GDPR transparency requirements

Case Study — Capital One Data Breach (2019): A misconfigured web application firewall in a cloud environment allowed an attacker to access over 100

million customer records, including names, addresses, credit scores, and Social Security numbers. The breach triggered parallel regulatory proceedings from the Office of the Comptroller of the Currency and the Consumer Financial Protection Bureau, civil class action litigation, and a \$190 million settlement. The incident demonstrated that technical misconfigurations have cascading legal consequences across multiple enforcement frameworks simultaneously — a dynamic that Domain 6 specifically prepares practitioners to anticipate and manage.

5. Analogy: The Legal Framework as a Building Code

Think of Domain 6's legal and compliance landscape as the building code that governs construction in a city. Technical security controls are like the physical materials and engineering: walls, wiring, fire suppression systems. They matter enormously. But no contractor starts building without checking which codes apply to the site, which inspections are required, and which materials are mandated for the building's intended use. A building that is structurally sound but violates the fire code is still a building that will be shut down. Domain 6 is the building code for cloud security programs. It does not replace technical controls; it defines the framework within which those controls must operate to be legally defensible.

6. Exam Focus

Domain 6 accounts for 13 percent of CCSP exam questions. The ISC2 exam approach for this domain emphasizes applied judgment over definition recall. Candidates who memorize framework names without understanding the relationships between them typically struggle with scenario questions that require selecting the correct legal framework for a specific data type and jurisdiction combination.

What ISC2 tests in this domain:

- Scenario-based jurisdiction questions: given a cloud deployment spanning multiple countries with specific data types, identify which legal frameworks apply and how conflicts should be resolved.
- Risk treatment selection: given a regulatory constraint, identify which treatment strategies are available and which are precluded by compliance obligations.
- Audit report type selection: given a customer's use case (financial controls, security posture verification, public disclosure), identify the appropriate SOC report type.
- Contract provision identification: given a scenario describing a cloud agreement, identify which provisions are missing or inadequate.
- Data role questions: distinguish controller, processor, and steward roles and identify which carries legal liability under GDPR.
- eDiscovery and forensic standards: apply the correct ISO/IEC standard to a described investigation scenario.

Common distractors include answer options that apply the correct framework but to the wrong jurisdiction, options that confuse contractual obligations with regulatory mandates,

and options that select a technically correct risk treatment that is precluded by a compliance requirement stated in the scenario.

7. Key Terms Glossary

PII (Personally Identifiable Information): Any data that can identify a specific individual, either alone or in combination with other data elements.

PHI (Protected Health Information): Health-related PII regulated under HIPAA in the United States, covering diagnosis, treatment, payment, and related information tied to an identifiable individual.

eDiscovery: The process of identifying, preserving, collecting, processing, reviewing, and producing electronically stored information in response to legal or regulatory proceedings.

Digital Forensics: The investigation of security incidents using digital evidence, following documented procedures designed to maintain evidentiary integrity and support legal proceedings.

SOC 2: Service Organization Control 2 — an audit report assessing a service provider's controls related to security, availability, processing integrity, confidentiality, and privacy.

Data Controller: The entity that determines the purposes and means of processing personal data; carries primary legal liability under GDPR.

Data Processor: The entity that processes personal data on behalf of the controller; carries derivative liability under GDPR.

Risk Treatment: The decision about how to respond to an identified risk: avoidance, mitigation, transfer/sharing, or acceptance.

Right to Audit: A contractual provision granting the customer the right to verify the cloud provider's security controls through direct assessment or third-party audit.

SLA (Service-Level Agreement): A formal contract defining the performance standards a service provider commits to, including uptime guarantees, incident response timelines, and remedies for non-performance.

Gap Analysis: A structured assessment comparing an organization's current security posture against a target framework or regulatory requirement, identifying areas requiring remediation.

GDPR: The European Union's General Data Protection Regulation — the primary data protection law governing personal data of EU residents, with broad extraterritorial application.

8. Quick Revision Checklist

- ☐ I can name the six topic areas of Domain 6 and state the exam weighting (13%).

- ☐ I can describe how legal, contractual, and regulatory obligations differ from each other.
- ☐ I understand why Domain 6 questions require applied judgment rather than simple recall.
- ☐ I can list the major privacy regulations (GDPR, HIPAA, FERPA, COPPA, PIPEDA, DPDP Act) and their primary jurisdictions.
- ☐ I understand the difference between a data controller and a data processor under GDPR.
- ☐ I can name the four primary ISO/IEC forensic standards (27037, 27041, 27042, 27043) and their focus areas.
- ☐ I can distinguish SOC 1, SOC 2, and SOC 3 audit reports by purpose and audience.
- ☐ I understand the five risk treatment strategies and can identify which are available in a regulated context.
- ☐ I can identify key contract provisions relevant to cloud security (SLA, right to audit, incident notification, data return).
- ☐ I recognize that Domain 6 topics are interconnected: legal requirements shape audit scope, privacy regulations define data roles, and risk treatment feeds contract design.

9. Practice Questions

Question 1 (Scenario)

A European financial services firm stores customer transaction records in a US-based cloud provider's data centers. A US federal agency issues a lawful data access request under domestic law. The firm's data protection officer advises that complying would violate GDPR's restrictions on data transfers to foreign governments without meeting adequacy or safeguard conditions. What describes the firm's situation most accurately?

- A. The US law takes precedence because the data is physically stored in the United States, and the provider must comply.
- B. GDPR takes precedence because it is a supranational regulation that overrides all domestic laws.
- C. The firm faces conflicting legal obligations from two frameworks, neither of which simply defers to the other, and resolution may require legal challenge or diplomatic negotiation.**
- D. The firm should comply with GDPR by default and inform the US agency that its request is legally precluded.

Answer: C

A: Incorrect. Physical storage location does not determine sole legal jurisdiction. GDPR applies to personal data about EU residents regardless of where it is stored.

B: Incorrect. GDPR does not override other countries' domestic laws; it creates obligations for organizations processing EU resident data, but conflicting legal demands may require legal challenge rather than simple priority.

C: Correct. This is the defining nature of multi-jurisdictional legal conflict in cloud environments. Neither framework automatically prevails; organizations must navigate the conflict, often with legal counsel and by challenging demands through available legal mechanisms.

D: Incorrect. While GDPR compliance is required, unilaterally refusing a lawful government demand without legal challenge creates criminal liability risk in the demanding jurisdiction. The resolution is more complex than a simple refusal.

Question 2 (Scenario)

A global retailer operates cloud workloads across data centers in the EU, the US, and India. Its legal team has identified that data localization requirements in India mandate that certain categories of financial customer data be stored only within Indian borders. The organization's current architecture uses a global data lake that replicates all data to all regions for analytics purposes. The cloud security team has been asked to assess risk treatment options. Which treatment strategy is NOT available for the data localization requirement?

A. Mitigation — redesign the architecture to segregate Indian customer financial data into an India-only storage zone.

B. Avoidance — exit the Indian market to eliminate the obligation entirely.

C. Transfer — purchase cyber insurance to cover fines resulting from data localization violations.

D. Acceptance — document executive acknowledgment that the localization requirement exists and proceed with the current architecture.

Answer: D

A: Incorrect. Mitigation through architectural redesign is available and is likely the appropriate treatment.

B: Incorrect. Avoidance through market exit is a valid (if extreme) treatment option.

C: Incorrect. Transfer through insurance is theoretically available, though regulators in some jurisdictions treat insurance coverage for regulatory fines with skepticism.

D: Correct. Regulatory compliance mandates are not subject to risk acceptance in the usual sense. Knowingly operating in violation of a legal requirement is not an acceptable risk treatment strategy; it is a legal violation. Risk acceptance is only available for risks within the organization's discretionary control.

Question 3 (Scenario)

A healthcare technology company has integrated its patient portal with three cloud-based analytics vendors. During a compliance review, it is determined that one vendor receives patient name, date of birth, and diagnosis codes to power predictive health risk modeling. The vendor's contract contains a data processing addendum but no Business Associate Agreement. Which statement best describes the compliance status?

A. The arrangement is compliant because the data processing addendum satisfies the vendor management requirement.

B. The arrangement violates HIPAA because the vendor is receiving PHI without a valid Business Associate Agreement in place.

C. The arrangement is acceptable because predictive analytics is a permitted use of PHI under HIPAA's treatment, payment, and operations provisions.

D. The arrangement requires correction only if the vendor is located outside the United States.

Answer: B

A: Incorrect. A data processing addendum addresses GDPR-style processor obligations but does not satisfy HIPAA's Business Associate Agreement requirement, which is a separate, US-specific legal instrument.

B: Correct. HIPAA requires that any vendor receiving PHI on behalf of a covered entity or business associate must execute a Business Associate Agreement. A data processing addendum does not substitute for this requirement. The arrangement creates direct HIPAA liability for the covered entity.

C: Incorrect. Even for permitted uses, the disclosure of PHI to a third-party vendor requires a Business Associate Agreement. The permitted use category addresses what the data may be used for, not the procedural requirements for sharing it.

D: Incorrect. HIPAA Business Associate Agreement requirements apply based on the nature of the data and the recipient's role, not on the vendor's geographic location.

Question 4 (Mixed)

Which of the following best describes the difference between a SOC 2 Type I and a SOC 2 Type II audit report?

- A. SOC 2 Type I covers security controls only; SOC 2 Type II covers all five trust service criteria.
- B. SOC 2 Type I evaluates whether controls are suitably designed at a point in time; SOC 2 Type II evaluates whether controls operated effectively over a period of time.**
- C. SOC 2 Type I is for internal use; SOC 2 Type II is publicly available.
- D. SOC 2 Type I is prepared by the service organization; SOC 2 Type II is prepared by an independent auditor.

Answer: B

A: Incorrect. Both SOC 2 Type I and Type II can cover any combination of the five trust service criteria. The difference is not in which criteria are covered.

B: Correct. Type I is a design assessment at a specific date; Type II is an operating effectiveness assessment over a defined period (typically 6–12 months). Customers seeking assurance about ongoing operational effectiveness require a Type II report.

C: Incorrect. Both SOC 2 Type I and Type II are restricted-use reports shared only with specified parties. SOC 3 is the publicly available summary.

D: Incorrect. Both types are prepared by an independent auditor. The difference is the assessment period and the nature of the opinion rendered.

Question 5 (Mixed)

An organization's risk assessment identifies that a cloud-hosted application processes payment card data. The security team recommends accepting the residual risk of a data breach after implementing encryption and access controls, citing the low probability of exploitation. Why is this risk treatment approach problematic?

- A. Risk acceptance is never a valid treatment strategy.
- B. Payment card data processing is governed by PCI DSS, which mandates specific controls that cannot be substituted with risk acceptance.**
- C. The probability estimate is likely incorrect, making acceptance based on it unreliable.

D. Risk acceptance requires board-level approval, which the security team cannot provide unilaterally.

Answer: B

A: Incorrect. Risk acceptance is a valid treatment strategy for risks within the organization's discretionary control where the cost of additional mitigation exceeds the expected value of the risk.

B: Correct. Regulatory and contractual compliance mandates constrain risk treatment options. PCI DSS requires specific controls for cardholder data environments; an organization cannot satisfy PCI DSS through risk acceptance of non-compliance. The residual risk after mandatory controls is within scope for acceptance, but compliance itself is not optional.

C: Incorrect. While probability estimates can be imprecise, the core problem here is not the estimate's accuracy but the misapplication of risk acceptance to a compliance requirement.

D: Partially correct in practice, but not the primary reason the approach is problematic in this scenario. The fundamental issue is that PCI DSS compliance is mandatory, not discretionary.

Question 6 (Mixed)

Which ISO/IEC standard provides guidance specifically on the identification, collection, acquisition, and preservation of digital evidence?

A. ISO/IEC 27001

B. ISO/IEC 27037

C. ISO/IEC 27050

D. ISO/IEC 27043

Answer: B

A: Incorrect. ISO/IEC 27001 defines requirements for an Information Security Management System. It addresses security management broadly, not digital forensic evidence handling specifically.

B: Correct. ISO/IEC 27037 specifically covers the identification, collection, acquisition, and preservation of digital evidence, including competence requirements for personnel and handling procedures to maintain evidential integrity.

C: Incorrect. ISO/IEC 27050 covers electronic discovery (eDiscovery), not the forensic evidence collection process. It is related but distinct.

D: Incorrect. ISO/IEC 27043 covers incident investigation principles and processes broadly. ISO/IEC 27037 is the specific standard for evidence identification, collection, and preservation.

Question 7 (Mixed)

A cloud customer negotiates a contract with a cloud provider for a regulated financial workload. The contract includes an SLA guaranteeing 99.9% uptime and specifies data encryption requirements. Which additional provision is most critical from a legal and compliance perspective that the description suggests may be absent?

A. A warranty that the provider will never experience a security breach.

B. A right-to-audit provision allowing the customer to verify the provider's compliance controls through direct assessment or third-party review.

C. A multi-year contract term to ensure pricing stability for the regulated workload.

D. A data processing addendum to satisfy GDPR requirements.

Answer: B

A: Incorrect. Absolute breach warranties are neither realistic nor available in commercial cloud contracts. This is not a standard or enforceable provision.

B: Correct. For regulated workloads, the customer must be able to demonstrate to its own regulators that the provider's controls are operating effectively. Without a right-to-audit provision, the customer cannot fulfill this obligation. The description makes no mention of audit rights, which is the most significant gap for a regulated financial workload.

C: Incorrect. Pricing stability is a commercial concern, not a legal or compliance requirement. It does not address the customer's regulatory verification obligations.

D: Incorrect. While a data processing addendum may be required if EU personal data is involved, the scenario describes a financial workload, and the most critical missing provision for regulatory verification purposes is audit rights.

Question 8 (Mixed)

Under the GDPR, which role carries primary legal liability for decisions about the purposes and means of processing personal data?

- A. Data steward
- B. Data processor
- C. Data controller**
- D. Cloud service provider

Answer: C

A: Incorrect. Data steward is an operational role focused on data quality and governance within an organization. It is not a GDPR-defined role with statutory liability.

B: Incorrect. The data processor processes data on behalf of the controller and carries derivative liability under GDPR, but primary liability for processing decisions rests with the controller.

C: Correct. The data controller determines the purposes and means of processing and carries primary legal liability under GDPR, including obligations to ensure lawful basis, maintain records of processing activities, and fulfill data subject rights.

D: Incorrect. A cloud service provider may act as a data processor (processing customer data on behalf of the customer) or as a data controller (for its own business data), but the role is not inherently the controller. The customer organization typically acts as controller for its own customer data hosted in the cloud.

Question 9 (Mixed)

What is the primary purpose of maintaining a legal register in a cloud security program?

- A. To document all known vulnerabilities in the cloud environment for remediation tracking.
- B. To track which jurisdictions the organization operates in, the categories of data held, and the legal frameworks that apply to each combination.**
- C. To record the organization's legal disputes with cloud providers and their resolution status.
- D. To maintain copies of all signed cloud contracts for audit purposes.

Answer: B

A: Incorrect. A vulnerability register or remediation tracker serves this purpose. A legal register documents applicable legal obligations, not technical vulnerabilities.

B: Correct. A legal register provides a systematic view of the organization's legal obligations, allowing security teams to design controls that satisfy all applicable requirements and identify conflicts before deployment.

C: Incorrect. Legal dispute tracking is a function of the legal department, not a cloud security program instrument. The legal register is prospective and operational, not retrospective.

D: Incorrect. Contract storage is a contract management function. The legal register maps legal obligations to data types and jurisdictions, not to specific contracts.

Question 10 (Mixed)

Which of the following describes the Electronic Discovery Reference Model (EDRM)?

A. A mandatory regulatory standard that governs evidence collection procedures in US federal courts.

B. An ISO standard for digital forensics investigation procedures.

C. A framework that describes the full lifecycle of electronically stored information handling in legal proceedings, from information governance through production and presentation.

D. A cloud provider certification program for eDiscovery capability.

Answer: C

A: Incorrect. The EDRM is an industry-developed reference model, not a mandatory regulatory standard. It is a framework that provides structure for eDiscovery processes.

B: Incorrect. ISO/IEC 27043 covers forensic investigation procedures. The EDRM is not an ISO standard.

C: Correct. The EDRM defines the stages of the eDiscovery process: information governance, identification, preservation, collection, processing, review, analysis, production, and presentation. It provides a common reference framework for legal and IT teams.

D: Incorrect. The EDRM is a process framework, not a certification program. Cloud providers may reference their EDRM capabilities, but the model itself does not certify providers.